

|                                          |
|------------------------------------------|
| Introduction to Information Security LAB |
| Lab 7                                    |
| Instructor: Ms Wasifa Kanwal             |
| Semester: BS CS 3 <sup>rd</sup>          |

## **Lab: Designing an Information Security Policy and Security Awareness Program (ISO 27001 & NIST Mapping) and Analyzing Legal & Ethical Dilemmas**

### **Lab Objectives**

By the end of this lab, students will be able to:

1. Identify basic information security risks in an academic environment.
2. Develop a simple, structured Information Security Policy for a small organization.
3. Design a Security Awareness / Education Program for staff and students.
4. Perform a high-level mapping (blueprint analysis) of their work to ISO/IEC 27001 and the NIST Cybersecurity Framework.
5. Analyze medium-level legal and ethical dilemmas in information security.
6. Evaluate actions from ethical, legal, and professional viewpoints.

### **1. Scenario**

You are the Junior Information Security Officer for:

ABC Learning Institute a small private training institute with:

- 30 employees
- 200 students
- 2 computer labs
- Campus-wide Wi-Fi
- Official email accounts for staff
- An online Learning Management System (LMS) for assignments and grades

The management has requested that you:

1. Identify security risks that the institute may face.
2. Develop a basic Information Security Policy.
3. Design a Security Awareness Program for staff and students.

4. Show how your policy and program relate to ISO 27001 and the NIST Cybersecurity Framework.
5. Analyze legal/ethical dilemmas and recommend actions.

\*\*\*\*\*

## 2. Background Concepts

### Information Security Policy

A formal document that defines how an organization protects its information. It includes rules, responsibilities, and acceptable behavior for using systems and data.

### Security Awareness / Education Program

A structured set of activities (trainings, posters etc.) to teach users how to behave securely and follow policies.

### ISO/IEC 27001

An international standard for Information Security Management Systems (ISMS). It defines requirements and control areas such as access control, incident management, and awareness.

### NIST Cybersecurity Framework (CSF)

A widely used framework that organizes cybersecurity activities into five core functions:

1. Identify
2. Protect
3. Detect
4. Respond
5. Recover

### Legal & Ethical Dilemmas

Situations where security responsibilities conflict with moral judgment, privacy laws, or organizational policies.

\*\*\*\*\*

## Risk Identification

Identify at least five (5) information security risks for ABC Learning Institute.

For each risk, fill a table like this:

|   | Risk Description                                        | Who is Affected?         | Possible Impact                                      |
|---|---------------------------------------------------------|--------------------------|------------------------------------------------------|
| 1 | Students install unauthorized software in computer labs | Students, IT Dept        | Malware infection, data corruption, lab downtime     |
| 2 | Weak passwords used by staff for LMS/email              | Staff, IT                | Unauthorized access, grade manipulation, data breach |
| 3 | Public Wi-Fi misuse by students ( malicious sites)      | Students, IT, Management | Network slowdowns, legal issues, malware risk        |
| 4 | Loss/theft of staff laptop                              | Staff, Students          | Data leak, privacy violation,                        |

|   |                                                           |                |                                     |
|---|-----------------------------------------------------------|----------------|-------------------------------------|
|   | containing student data                                   |                | reputation damage                   |
| 5 | Phishing emails targeting staff with fake LMS login pages | Staff, Faculty | Credential theft, email compromise, |

- Minimum 5 risks.
- Each risk must clearly describe:
  - ✓ What can go wrong
  - ✓ Who is affected (students, staff, IT, management)
  - ✓ Impact (e.g., data leak, exam paper leak, reputation damage, service downtime, financial loss)

### **Deliverable: Risk Identification Table .**

## **Develop an Information Security Policy**

Create a 1.5 to 3-page Information Security Policy document for ABC Learning Institute.

Your policy must include at least the following sections:

### 1. Purpose

- ✓ Why the policy exists (e.g., to protect information, ensure privacy, maintain availability).

This policy aims to protect institutional information, ensure confidentiality of student and staff data, maintain system availability, and promote safe use of campus technology resources.

### 2. Scope

- ✓ Who and what is covered?
- ✓ Example: all employees, faculty, students etc

This policy applies to all employees, faculty, students , lab systems, servers, Wi-Fi networks, LMS systems, and email accounts.

### 3. Roles and Responsibilities

- ✓ Define responsibilities for:
  - Management
  - IT / System Administrator
  - Staff / Faculty
  - Students

**Management:** Approve policies, allocate budgets, enforce compliance.

**IT / System Administrator:** Maintain systems, apply updates, monitor networks, manage access controls.

**Faculty/Staff:** Follow acceptable use rules, secure passwords, protect institutional data.

**Students:** Use labs responsibly, follow Wi-Fi rules, avoid unauthorized software.

#### 4. Acceptable Use Policy (AUP)

- ✓ Rules for using:
  - Lab computers
  - Internet & Wi-Fi
  - Official email
  - Removable media (USB drives, external HDDs)
- ✓ Specify what is allowed and what is not allowed.

**Lab Systems:** Only academic software allowed; no games or hacking tools.

**Internet/Wi-Fi:** No illegal downloads, harmful browsing, or bypassing filters.

**Email Use:** Only for academic or official purposes; avoid forwarding spam.

**USB Devices:** Only allowed after antivirus scan; avoid unknown USB drives.

#### 5. Password Policy

- ✓ Minimum password length and complexity
- ✓ Password change frequency (if applicable)
- ✓ Rules about sharing or writing down passwords.

Minimum 10 characters, must include letters, numbers, and special characters.

No sharing of passwords or writing them on paper.

LMS and email passwords must be changed every 90 days.

#### 6. Data Protection and Privacy

- ✓ How student and staff data (personal data, grades, records) must be handled and protected.
- ✓ Any rules on storage, sharing, and access.

Student records, grades, and personal information must be stored only in authorized systems.

Data must not be shared externally without permission.

Staff laptops must use password protection and encryption .

## 7. Email and Communication Policy

- ✓ Use of official email accounts
- ✓ Handling suspicious emails, links, and attachments
- ✓ Prohibition of illegal or inappropriate use.

Do not open suspicious attachments or links.

Report phishing attempts to IT immediately.

Use official email for institute business only.

## 8. Incident Reporting

- ✓ What is considered a security incident?
- ✓ Who should be notified?
- ✓ Time frame for reporting (e.g., within 24 hours).

Incidents include malware infection, suspicious email, lost devices, or unauthorized access.

Report incidents to IT within 24 hours.

## 9. Policy Enforcement and Disciplinary Actions

- ✓ Consequences of violating the policy (warnings, access restrictions etc).

Violation may result in warnings, loss of access rights, disciplinary action, or legal reporting depending on severity.

**Deliverable : “ABC Learning Institute – Information Security Policy” document.**

## **Design a Security Awareness / Education Program**

Design a 6-month Security Awareness Program for ABC Learning Institute.

Your program should include:

### 1. Objectives

- ✓ At least 3 clear objectives, e.g.:
  - Reduce phishing-related incidents among staff and students.
  - Promote secure password practices.
  - awareness of safe internet and lab usage.

### 2. Target Audience

- ✓ Who will be trained?

✓ For example:

- Faculty
- Administrative staff
- Students (especially lab users)

### 3. Training / Awareness Activities

✓ At least 4–6 activities, such as:

- Monthly awareness sessions or workshops
- Monthly workshops
- Email newsletters
- Posters on campus
- Phishing simulation exercises

### 4. Schedule / Timeline

✓ Prepare a simple month-wise plan, for example:

| Month | Activity                                      | Audience         |
|-------|-----------------------------------------------|------------------|
| 1     | Intro session: Basics of information security | Staff + Students |
| 2     | Email campaign: Phishing awareness            | Staff            |

### 5. Evaluation / Measurement

➤ How will you measure effectiveness? (examples)

- Quiz scores
- Phishing simulation results
- Attendance records
- Reduction in security incidents

## **Deliverable : Security Awareness Program**

## **Mapping to ISO 27001 and NIST (Blueprint Analysis)**

Perform a high-level mapping between your work and the two standards/frameworks.

### **Part A – ISO/IEC 27001 Mapping**

Create a simple table that shows which parts of your policy and program relate to which ISO 27001 control areas (at a high level).

Example

| <b>Policy Element</b> | <b>Related ISO 27001 Category</b>                                                                                                                                                                                                                                                                                                                                          |
|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Password Policy       | <ul style="list-style-type: none"> <li>• A.5.15 Access Control</li> <li>• A.5.17 Authentication Information</li> <li>• A.8.5 Secure Authentication</li> </ul>                                                                                                                                                                                                              |
| Acceptable Use Policy | <ul style="list-style-type: none"> <li>• A.5.10 Acceptable Use of Information and Other Associated Assets</li> <li>• A.7.7 Clear Desk and Clear Screen</li> <li>• A.8.23 Web Filtering</li> </ul>                                                                                                                                                                          |
| Data Protection Rules | <ul style="list-style-type: none"> <li>• A.5.12 Classification of Information</li> <li>• A.5.13 Labelling of Information</li> <li>• A.5.14 Information Transfer</li> <li>• A.5.34 Privacy and Protection of PII</li> <li>• A.8.24 Use of Cryptography</li> </ul>                                                                                                           |
| Incident Reporting    | <ul style="list-style-type: none"> <li>• A.5.24 Information Security Incident Management Planning and Preparation</li> <li>• A.5.25 Assessment and Decision on Information Security Events</li> <li>• A.5.26 Response to Information Security Incidents</li> <li>• A.5.27 Learning from Information Security Incidents</li> <li>• A.5.28 Collection of Evidence</li> </ul> |
| Awareness Program     | <ul style="list-style-type: none"> <li>• A.6.3 Information Security Awareness, Education and Training</li> <li>• A.5.7 Threat Intelligence</li> </ul>                                                                                                                                                                                                                      |

You are not expected to know exact control numbers; just map conceptually.

## **Part B NIST Cybersecurity Framework Mapping**

Map some of your tasks to the five NIST CSF functions:

- Identify
- Protect
- Detect
- Respond
- Recover

### **Example:**

| <b>Activity / Policy Element</b>  | <b>NIST Function</b> |
|-----------------------------------|----------------------|
| Risk Identification Table         | Identify             |
| Password Policy                   | Protect              |
| Email Safety & Phishing Detection | Detect               |
| Incident Reporting Procedure      | Respond              |
| Backup & Recovery Guidelines      | Recover              |

**Deliverable : ISO 27001 & NIST mapping (tables).**

<https://hightable.io/iso-27001-annex-a-controls-list/>

